

	C-Directive 09000	Issue/Amendment 1	Page 1/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

Table of contents

1	Subject Matter, Objective, and Purpose	2
2	Scope	2
3	Definitions and Abbreviations	3
4	Conventions.....	8
4.1	Cybersecurity Management System (CSMS) (ND)	8
4.2	Roles and Responsibilities	9
4.3	Cybersecurity Life Cycle (ND)	19
4.4	PDCA Cycle (ND)	27
4.5	Update of Attachments (ND)	28
4.6	Deviation Requests (ND)	28
	Attachments.....	29
	Revision History	30



	C-Directive 09000	Issue/Amendment 1	Page 2/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

1 Subject Matter, Objective, and Purpose

- (1) Connected products, digital services, and IT infrastructures are becoming increasingly widespread in all areas of life, business, and environments. For Bosch as a technology company, this development provides great economic potential, on the one hand through innovative products for our customers, and on the other hand through the digitalization of all business processes, on which Bosch's future competitive position largely depends.
- (2) At the same time, the significant economic opportunities of digitalization are associated with considerable cybersecurity risks. Their occurrence can be devastating for individuals and organizations. The manipulation of IT Systems, products, and people in cyberspace can lead not only to data loss, financial damage, or legal violations, but also to risks for health and life.
- (3) The key for cybersecurity is a regulatory framework that provides guidance with respect to processes and controls. These shall prevent a compromise of Bosch's elements of cyberspace, enable a timely detection and isolation of communication lines between attackers and affected systems and network connections. It shall contain and neutralize malicious activities, help to recover from attacks.
- (4) The goal of this C-Directive is to provide a cybersecurity management system (CSMS) to ensure the continued function and resilience of capabilities and assets, required for Bosch's business operations in the context of cybersecurity. It provides the rules and underlying framework on which the cybersecurity strategy with its two pillars of protection in breadth for all assets, and protection in depth for the business-critical assets, can be implemented. The CSMS is closely aligned with other management systems, for example, the Information Security Management System (ISMS, see [RBGF 105](#)) and the Risk Management System (RMS, see [RBGF 104](#)). These management systems do not work independently but are interdependent and cybersecurity measures are often integral to information security strategies, and vice versa. Therefore, CSMS and ISMS make use of common data bases to allow mapping of external requirements on internal processes. The CSMS is defined by this document and the *Attachment 1: Cybersecurity Requirements Catalogue*. *Attachment 2: Corporate Department for Cybersecurity* adds tasks and services implemented by C/CY. *Attachment 3: RBGF 177-001 Systems Mapping* defines additional requirements for IT Systems included in the systems in scope of [RBGF 177-001](#).
- (5) This C-Directive includes both IT Systems (see [RBGF 177](#)) and Bosch Products (see [RBGF 182](#)). These systems are part of Bosch's elements in cyberspace.

2 Scope

- (1) This C-Directive is binding for the Bosch Corporate Group. For BEGE (see [RBGF 100](#)), which do not belong to the Bosch Corporate Group (see [RBGF 100](#)), it is recommended that they adopt the content of this C-Directive by their own decision. For organizations that are not part of the Bosch Corporate Group, but are using the Bosch network, the content of this C-Directives must be adopted by contracts.



	C-Directive 09000	Issue/Amendment 1	Page 3/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

- (2) Legal regulations take precedence. If such regulations are in conflict with the requirements of this C-Directive, C/CY must be informed immediately, and subsequent actions must follow the process defined by C/CY in advance.
- (3) For IT Systems used by or part of Manufacturing, Logistics, or Global Real Estate equipment and operated within a domain specific and isolated network segment or not connected at all (stand-alone), CD 09000 must be implemented after the disentangling. **Until CD 09000 has been fully implemented**, the cybersecurity risks not addressed by CD 04602 remain with the OE management.

In agreement with the owner of CD 04602 we aim to disentangle the cybersecurity requirements of CD 04602 into CD 09000 as soon as possible, but latest by 01.04.2026. Based on this outlook it is strongly recommended to develop a trustworthy plan to fulfill CD 09000.

- (4) **This C-Directive replaces CD 07900 version 2 dated August 01, 2022, and CD 07000 version 1 dated November 22, 2021. The leading language of this regulation is English.**

3 Definitions and Abbreviations

Account: An account is used for identification, authentication, and authorization.

Administrator: Administrator is a user with administrative (privileged) permissions for managing IT Systems.

Asset: Assets are everything that is of value to the institution and therefore **requires protection**. In cybersecurity at Bosch the Bosch IT systems and Bosch Products and their components represent the assets to be protected.

Authentication: Authentication is the verification of a user during log-on to an IT System.

Bosch: Bosch is in this CD used as synonym for the Bosch Group (see RBGF 100).

Bosch Corporate Network (BCN): The BCN is a Bosch managed private network and is the central communication domain for the internal Bosch IT.

Bosch Essential and Integral cyberSecurity Architecture (EISA): Bosch EISA defines policies, requirements, and responsibilities to address cybersecurity risks at Bosch.

Bosch Network: A Bosch managed private network and a communication domain for the internal Bosch IT.

Bosch Product (see RBGF 182): Bosch Product as defined in RBGF 182 but limited to products that process digital data.



	C-Directive 09000	Issue/Amendment 1	Page 4/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

Digital touchpoints as defined in CD 02900 are covered by the product definition in RBGF 182 and are therefore Bosch Products.

Responsibilities for different trade good categories (HAWA) are defined in CD 80008 and apply to cybersecurity accordingly.

Bosch Single Sign-On (SSO): Bosch single sign-on (Bosch SSO) is the central authentication system (Identity Provider) based on the Bosch Corporate Directory (BCD) provided by the Bosch single sign-on team. It enables users to access multiple IT Systems and IT applications with a single set of credentials and a one-time logon experience.

Business Critical Asset (BCA): Asset having potential to significantly impact on the achievement of the organization's objectives. See CGP 09000-006.

Control: See RBGF 109.

Crisis (see RBGF 184): A sudden and/or unexpected and temporary event with a regional, GE-related or corporate dimension, which by itself or in the course of its development has the potential to cause severe financial or reputational damage for the respective business and cannot be handled by the organizational structure (according to RBGF 101) or by pre-defined processes (e.g., "dawn raids").

Cryptographic Material: A value used to control cryptographic operations, such as decryption, encryption, signature generation, or signature verification.

Cyber Threat Intelligence (CTI): Cyber threat intelligence (CTI) is the collection and analysis of information from accessible sources with the aim of building knowledge about cyber threat methods and procedures. Cyber threat information is any information that can help Bosch identify, assess, monitor, and respond to cyber threats and enables Bosch to make an informed decision about its Cybersecurity posture.

Cyberattack: Attempt to destroy, expose, alter, disable, steal, or gain unauthorized access to or make unauthorized use of an asset.

Cybersecurity (see RBGF 177): The application of security measures to protect or ensure the continued function and resilience of capabilities and assets in cyberspace against intentional attacks. In enterprise context cybersecurity activities comprise Enterprise IT, Product IT and OT.

Cybersecurity Incident Response Plan (CIRP): A cybersecurity incident response plan (CIRP) is a set of written instructions for detecting, responding to and limiting the effects of an IT security event.

Cyberspace (see RBGF 177): The global domain consisting of all interconnected communication, information technology and other electronic systems, networks, and their data, as well as those which are separated or independent, which process, store or transmit data.



	C-Directive 09000	Issue/Amendment 1	Page 5/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

Differentiation Option (DI) (see RBGF 103): A binding parameter with the option of differentiation in the implementation path (regulation characteristic DI). More than one implementation path can be defined.

Enterprise IT (see RBGF 177): IT with the main purpose of supporting internal processes.

External Service Provider: An external service provider is an enterprise that is an own legal entity separate from the Bosch Group that provides services such as consulting, IT services and software development to a legal entity of the Bosch Group.

IT Application (see RBGF 177): An IT application is a functionally integrated and configured, operational instance of a software product to support and fulfill functions and processes.

IT End Device: IT end devices are IT Systems used by the user for processing information, e.g., laptops, manufacturing PCs, smartphones and tablets.

IT Owner (see RBGF 177): IT owner is the manager of the organizational office, which makes the IT System available (to others or just for own usage) and manages it.

IT System (see RBGF 177): An IT System is anything that is operated by or on behalf of the Bosch Corporate Group to process (incl. acquires, stores, or distributes) electronic data (information).

IT Systems with very high Protection Requirements: IT Systems with very high protection requirements in the sense of this CD are IT systems,

- that are intended for processing of data of security class 3 (C-SC, I-SC or A-SC), or
- that are necessary for the functional or access control of such IT systems, or
- that are essential for the administration, provision, or recovery of systems in the scope of RBGF 177-001, or
- that have been approved by the OE management as "business critical assets" (BCA) based on the CGP 09000-006, or
- that have been identified and agreed upon with the affected party as requiring very high protection as part of C/CY assessments (see Chapter 4.5 PDCA).

Examples of IT Systems with very high protection requirements are directory services, software distribution, client/server management, backup services, automation services, administration services, or network management.

Information Security (see RBGF 105): Aims to protect information in any form, digital or non-digital; focusing on confidentiality, integrity, and availability of information.

Information- or cybersecurity incident (see also CD 02900): An information- or cybersecurity incident is the compromise of security (e.g., in IT Systems) that results in the destruction, loss, modification, or unauthorized disclosure of or access to information (that has been transmitted, stored, or otherwise processed) that may result in negative consequences for the Bosch Group



	C-Directive 09000	Issue/Amendment 1	Page 6/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

(e.g., loss of reputation, disruption of business processes, outflow of funds, etc.) See also CD 02900 “ISP-CD Information Security and Data Protection”. An information- or cybersecurity incident does not need to already have led to a tangible damage, also the high possibility of a damage can be sufficient to define an activity as an incident.

Measure: Measures are all means for managing risks including policies, processes, procedures, or organizational structures, which can be of an administrative, technical, managerial, or statutory nature.

Network: The network is a well-defined logical communication domain, within the operative and administrative responsibility of the IT owner of the network. This means, the IT owner of the network is able to enforce the adherence of specification for communication within the network and at the network perimeter.

Network Device: The network device is an IT System that is specifically designed for operating the network infrastructure.

Network Infrastructure: Network infrastructure describes the infrastructure of a network consisting of network devices (IT Systems like routers, switches, firewalls, etc.) and interconnecting links.

Network Perimeter: The network perimeter defines the demarcation between networks, e.g. the Bosch network and external potentially untrusted networks.

Network Segment: A network segment is a subnetwork separated based on trust levels with defined policies for inbound and outbound access.

No Differentiation Option (ND) (see RBGF 103): A binding parameter with a non-differentiable implementation path. The implementation path has to be adhered to regardless of effort or costs (however as economically as possible).

OE Management: See RBGF 100.

Operational Technology (OT) (see NIST SP 800-37): Programmable systems or devices that interact with the physical environment (or manage devices that interact with the physical environment).

PIN: PIN stands for personal identification number. It is not the same as a password because a PIN is generally tied to and requested by a device (e.g., TPM or Smartcard) to unlock cryptographic material.

Password: A password is information that serves as authentication and confirms identity as uniquely as possible.

Penetration Test: Penetration tests, or pentests, are authorized simulated attacks conducted by skilled security professionals to identify vulnerabilities in an organization's systems, networks, or applications. They can help identifying vulnerabilities, testing security controls, assessing risks, validating compliance, and improving incident response.



	C-Directive 09000	Issue/Amendment 1	Page 7/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

Policy Enforcement Point: The policy enforcement point controls access to a network segment or a trusted zone.

Privileged Account: A privileged account is an account that is authorized to perform changes on the security and system configuration of an IT System, and/or that can directly or indirectly (by changing permissions) access all data stored on an IT system.

Product IT (see RBGF 177): IT as Bosch Product or as part of a Bosch Product (RBGF 182).

Product Responsible Office (see RBGF 182): The position in a product responsible OE that assumes responsibility for product compliance of a Bosch Product over its life cycle.

Protection in Breadth: Establishing resilience for all products, services, and systems of Bosch in cyber space against untargeted attacks, thereby providing the optimal balance between risk exposure and protection level.

Protection in Depth: Implementing highly developed security measures, processes, and capabilities for business-critical products, services, and systems with high protection needs against targeted attacks.

Risk: Effect of uncertainty on objectives. (ISO 31000).

Self-Assessment: See RBGF 109 (Control self-assessment).

Server: Servers (hardware and operating system) are IT Systems in a group of networked computers that provide applications or services for multiple users, computers, or systems (e.g., machines, test facilities).

Shared Account (see CD 02900): A shared account is an account that is used by several users (e.g., by sharing a password) and isn't assigned exclusively to one user. Typical examples are kiosk/ display systems in OT environments, built-in accounts, and emergency accounts.

Technical Account (see CD 02900): A technical account is used to authenticate technical services (non-person, no user) on an IT System internally or in IT System to IT System communication. Typical examples are services, daemon, application runtimes, database connections and APIs.

Threat: A threat is a possible cause of an unwanted event that can result in damage.

User: The user is a person who uses an IT System. In the context of this CD, users are associates of the Bosch group as well as external associates. Persons and external customers, using products, are not Users in that sense.

Vulnerability (see ISO/IEC 27000): Weakness of an asset that can be exploited by one or more threats.



	C-Directive 09000	Issue/Amendment 1	Page 8/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

4 Conventions

4.1 Cybersecurity Management System (CSMS) (ND)

- (1) The CSMS defines requirements, processes, and responsibilities for IT Systems and Bosch Products to address cybersecurity risks at Bosch. CD 09000 "Cybersecurity" defines its binding part which is extended by additional information in the Bosch "Essential and Integral cyberSecurity Architecture" (Bosch EISA). Driven by an increasing and rapidly changing threat landscape, the CSMS is continuously updated to transparently reflect the continuous development of requirements, procedures, and technology in the cybersecurity context. Hereby it is aligned to international standards (e.g., BSI Grundschrift, ISO 27002:2022).
- (2) The development, alignment, update, and release process depicted in Figure 1 can be initiated, for example, by the OE Cybersecurity Officer (see 4.2.2), C/CY services (see Attachment 2), or other stakeholders and is established to address:
 - integration of feedback and gained knowledge,
 - improvement of existing cybersecurity policies and procedures,
 - transparent communication of changes,
 - adoption to changes in the threat landscape,
 - identification of new cybersecurity risks,
 - integration of new or updated external regulations or standards.
- (3) The provided feedback and corresponding information are analyzed and reviewed by C/CYG. Required changes and improvements, for example, on cybersecurity requirements, are aligned with relevant stakeholders and then incorporated into the CSMS by C/CYG. The results are then updated and published. Existing regulations and procedures are reviewed at least every 3 years in accordance with [RBGF 103](#) by C/CYG. Distribution lists are available and can be used to be informed about updates on the CSMS.



	C-Directive 09000	Issue/Amendment 1	Page 9/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

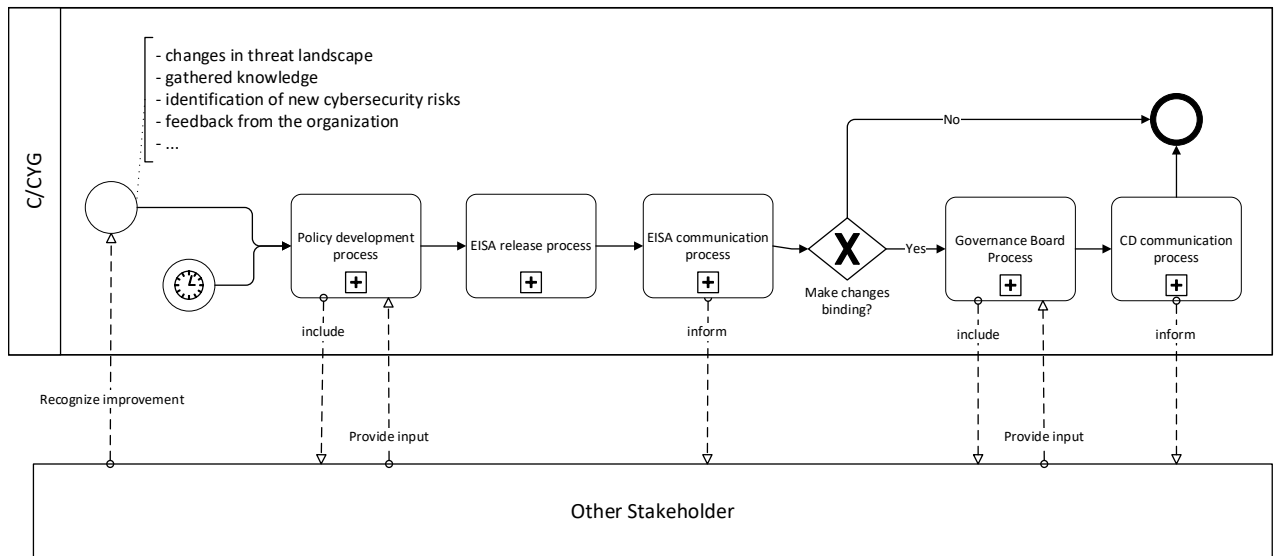


Figure 1: **Cooperative development, alignment, update, and release process**

- (4) In addition to the documentation of the basic requirements supporting the implementation of the state of the art in cybersecurity (see 4.3.1.2), Bosch EISA is used to retrieve feedback for upcoming versions of CD 09000 "Cybersecurity". In this context, at least one review and feedback round is performed before the official Governance Board process (see [RBGF 103-100](#)) is followed to get the approval of the Board of Management for the release of a new version of CD 09000. The release of the new version then follows the defined communication channels using the distribution lists for Corporate Directive updates and is also incorporated in Bosch EISA. The changes of the different versions of the Bosch EISA are documented and available in the version history.

The details of the processes including the possibilities to register for the distribution lists are documented [here](#).

4.2 Roles and Responsibilities

- (1) Figure 2 provides an overview of the roles described in this document.



	C-Directive 09000	Issue/Amendment 1	Page 10/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

	Bosch Group	OE	IT System / Product	Bosch Location
Scope	Cybersecurity of Bosch elements in cyberspace	Cybersecurity of IT Systems and Bosch Products in the responsibility of the OE	Cybersecurity of a single IT System or Bosch Product	Cybersecurity tasks requiring physical presence in a Bosch location (relevant for Bosch Enterprise IT only)
Overall Responsibility	RB Board of Management	OE Management	IT Owner / Product Responsible Office	
Cybersecurity relevant Roles	C/CY	OE Cybersecurity Officer (CSO)	Security Manager (Security Engineer)	Local Cybersecurity Contact (Local CSC)

Figure 2: Overview of cybersecurity overall responsibility and relevant roles

- (2) One person can hold multiple roles. In this case, the person must have the necessary expertise and capacity. There must be no conflict of interest.

4.2.1 OE Management (ND)

- (1) The OE management has the overall responsibility for cybersecurity risks arising from IT Systems or Bosch Products in the responsibility of the respective OE.
- (2) The OE management must ensure an effective delegation of cybersecurity within the OE by implementing adequate organizational structures and roles as defined in this document. To this end, the OE management:
 - Must ensure that the roles defined in the subsequent sections are staffed with adequate expertise and enabled with the necessary authority,
 - Must assign the necessary resources, particularly budget and headcounts. The complexity and diversity of the IT Systems and Bosch Products in the responsibility of the OE must be considered in the allocation of resources for cybersecurity.

4.2.2 OE Cybersecurity Officer (OE CSO) (ND)

- (1) The OE management must nominate an OE Cybersecurity Officer.
- (2) The OE CSO is responsible for cybersecurity within the OE as defined in section 4.2.2.1. This responsibility is assumed on behalf of the OE management.
- (3) The OE CSO must have the necessary technical expertise (see section 4.2.2.2).
- (4) The OE CSO role must be assigned to an associate of the Bosch Corporate Group.
- (5) The OE CSO must be empowered by the OE management to assess the cybersecurity in the OE and make decisions accordingly, e.g., regarding vetoes, annual management reporting, and risk reporting.
- (6) The OE CSO role may be shared between up to two persons with different focus areas, e.g., Enterprise IT or Bosch Products. In this case, the responsibilities, focus areas, reporting paths, and decision-making processes must be transparently documented. The cooperation



	C-Directive 09000	Issue/Amendment 1	Page 11/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

between the OE CSOs must ensure that all OE CSO tasks are covered. For the case that a consensus between the two persons cannot be achieved, an escalation path in the OE must be defined and documented.

- (7) Enabled by the OE management, the OE CSO must establish a sub-structure within the OE if this is required to ensure an effective implementation of the OE CSO rights and responsibilities within the OE.

4.2.2.1 Rights and Responsibilities

The implementation of the cybersecurity requirements for individual IT Systems or Bosch Products in section 4.3 and Attachment 1 is in the responsibility of the respective IT Owner or Product Responsible Office.

4.2.2.1.1 Coordination

The OE CSO:

- (1) Acts as the OE's first point of contact within the OE for cybersecurity,
- (2) Must align the cybersecurity activities within the OE with other relevant roles and stakeholders, e.g., QM (see [RBGF 179](#)), PCO (see [RBGF 182](#)), ISP Office (see [RBGF 105](#)), Industrial-IT representative (see [CD 04602](#)), BDO (see [RBGF 177](#)), or RMO (see [RBGF 104](#)),
- (3) Must distribute cybersecurity-relevant information provided by C/CY within the OE.

4.2.2.1.2 Governance

The OE CSO supports the governance function of C/CY. Therefore, on behalf of the OE management, the OE CSO:

- (1) Must develop and implement a roll-out plan for this C-Directive within the OE. This includes, for example, ensuring that the requirements of this C-Directive for IT Systems and Bosch Products (see section 4.3 and Attachment 1) are integrated in the OE's relevant processes, e.g., IT operations, Bosch Product development, Bosch Product operation, quality, or purchasing. The roll-out plan must take into account the Bosch cybersecurity strategy with its two pillars: protection in depth for the business-critical assets and protection in breadth for all assets,
- (2) Must monitor the implementation of this C-Directive within the OE and at least once a year derive measures for improvement of the cybersecurity within the OE,
- (3) Must evaluate deviation requests from the relevant cybersecurity processes and requirements in this C-Directive before the deviation requests are forwarded to C/CY,
- (4) Has the right to veto all cybersecurity-related activities in the OE and to report the cybersecurity-related risks to the OE management.



	C-Directive 09000	Issue/Amendment 1	Page 12/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

OE CSOs may define additional OE-internal cybersecurity regulations if these are consistent with this C-Directive and approved by the OE management.

4.2.2.1.3 Competence Management

- (1) The OE CSO must establish an OE-specific cybersecurity competence management program. C/CY supports OEs by providing a suitable training portfolio and curricula for cybersecurity relevant roles mandated by this C-Directive. Additional OE-specific cybersecurity training measures must be defined by the OE CSO.

4.2.2.1.4 Vulnerability Management

- (1) The OE CSO must ensure that the OE's vulnerability management processes and technologies are aligned and integrated with the C/CY vulnerability management processes and technologies and are established within the OE.

Alignment and integration of vulnerability management technologies with C/CY includes, e.g., alignment of tools, formats, and APIs.

- (2) The OE CSO must ensure that upon request and in case of critical vulnerabilities, a report of affected IT Systems and Bosch Products can be compiled including a mitigation plan.

The reporting of the status of vulnerability handling is expected only for critical vulnerabilities, e.g., log4shell. Reporting may be necessary for different stakeholders, e.g., OE management, Bosch board of management, or external authorities. Regular reporting is currently not planned.

- (3) The OE CSO must ensure that vulnerabilities with potential safety relevance are reviewed with the OE QM without delay.
- (4) The OE CSO must define the criteria for "software trustworthiness" (see Attachment 1, EISA-OPS-602).

4.2.2.1.5 Incident Response

- (1) The OE CSO must support Bosch CERT regarding cybersecurity incidents where IT Systems or Bosch Products in the responsibility of the OE are affected.

4.2.2.1.6 Reporting

The OE CSO:

- (1) Has the right to directly report cybersecurity-relevant topics to the OE management,
- (2) Must report the cybersecurity status within the OE at least annually to the OE management,



	C-Directive 09000	Issue/Amendment 1	Page 13/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

- (3) Must report the cybersecurity status within the OE at least annually to C/CY,
- (4) Must report the OE's cybersecurity risks with relevance to the Bosch Risk Management System (see [RBGF 104](#)) in cooperation with the OE's Risk Management Officer (RMO).

Additional ad-hoc reporting to the OE management or to C/CY may be required, e.g., in case of incidents, critical vulnerabilities, or vetoes.

4.2.2.2 Required Competences

- (1) The OE CSO must fulfill at least one of the following requirements:
 - Suitable academic background, e.g., master in computer science,
 - Or at least 5 years' experience proving the necessary technical expertise in either cybersecurity or related technical areas, e.g., IT operations or software development.
- (2) The OE CSO must have the necessary communication and networking skills to communicate to the OE management and to maintain an OE internal network as well as participate in OE external networks.



	C-Directive 09000	Issue/Amendment 1	Page 14/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

The following table provides guidance for the competence profile of an OE CSO based on the [Bosch competence model](#). The competence levels (1=Awareness to 5=Champion) are defined in the [Professional Development Journey \(PDJ\)](#). By the time of writing this C-Directive, trainings are being defined to support the OEs to cover a sub-set of these competences.

Competence	Competence level (1-5)
Secure software development	Domain specific: 3 competences with level 3 (Advanced)
Security testing	
Communication and network security	
Cloud security	
Web security and application security	
Cryptography	
Identity and access management	
Security architectures and engineering	
Security of connected products	
Hardware security	
Embedded security	
Incident response	3
Risk management	3
Vulnerability management	3
Cybersecurity relevant laws, regulations, and standards	2
Product liability	2
Project management skills	2
Knowledge of the target domain	3
Knowledge of the OE's operational procedures along the product or IT System life cycle.	3
Leadership skills	4
Communication and moderation skills	3
Cooperation and networking skills	3
Trainings and coaching skills	3



	C-Directive 09000	Issue/Amendment 1	Page 15/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

4.2.3 IT Owner or Product Responsible Office (ND)

- (1) The OE management must ensure that for every IT System and Bosch Product in the responsibility of the OE, an IT Owner (see [RBGF 177](#)) or Product Responsible Office (see [RBGF 182](#)) is defined and documented. The IT Owner or Product Responsible Office is responsible for the respective IT System or Bosch Product during the entire life cycle.

The IT Owner or Product Responsible Office is typically responsible for several other topics beyond cybersecurity, e.g., development, operation, safety, costs, or quality. **In this C-Directive, only the cybersecurity relevant topics are documented.**

- (2) In case of a missing or unclear assignment, the role IT Owner or Product Responsible Office remains with the OE management.
- (3) The role IT Owner or Product Responsible Office must be continuously maintained and documented during the overall life cycle of the IT System or Bosch Product:
- Despite of organizational changes
 - During handover of ownership / responsibility during the life cycle.
- (4) In case of a handover of the ownership / responsibility, the previous IT Owner or Product Responsible Office must hand over the complete documentation of the IT System or Bosch Product to the successor.

4.2.3.1 Rights and Responsibilities

The IT Owner or Product Responsible Office:

- (1) Must ensure that the IT System or Bosch Product is compliant with cybersecurity-relevant legal requirements,
- (2) Must ensure that the IT System or Bosch Product fulfills the requirements of this C-Directive,
- (3) Must ensure that sufficient cybersecurity know-how and resources are available to ensure compliance with this C-Directive. For example, this can be achieved with the support of a Security Manager (see also section 4.2.4). The know-how must be continuously updated,
- (4) Must provide information about the cybersecurity status of the IT System or Bosch Product to the OE CSO or to C/CY upon request,
- (5) Must provide information relevant for the secure usage of the IT System or Bosch Product, e.g., to the IT Users, or customers,

For example, this can be documented in the relevant IT Service Level Agreement (SLA), Operational Level Agreement (OLA), product manual, or technical customer documentation.

- (6) Must ensure that cybersecurity risks of the IT System or Bosch Product (e.g., resulting from a Threat Analysis and Risk Assessment or a Penetration test) are transparently communicated to the relevant stakeholders who can take a decision on the risk treatment, e.g., Project Sponsor or OE management. The OE CSO must be informed.



	C-Directive 09000	Issue/Amendment 1	Page 16/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

4.2.4 Security Manager (Security Engineer) (ND)

- (1) For every Bosch Product, the Product Responsible Office must ensure that the role Security Manager is assigned during the overall life cycle of the Bosch Product.
- (2) For IT Systems in the scope of [RBGF 177-001](#), the IT Owner must ensure that the role Security Manager is assigned during the overall life cycle of the IT System. For other IT Systems, the role Security Manager is recommended.
- (3) If no Security Manager is assigned, the rights and responsibilities of the Security Manager remain with the Product Responsible Office or IT Owner.
- (4) The assignment of the role must be continuously maintained and documented during the overall life cycle of the IT System or Bosch Product. Organizational changes or changes of the life cycle phase (e.g., from development to operation) must not lead to a loss of the role and the respective documentation.

The role Security Manager is formerly known as Project Security Manager (PSecM) for Bosch Products. The main difference is that the Security Manager is now required during the overall life cycle. Additionally, it is introduced to a sub-set of the IT Systems in the Enterprise IT.

OEs may call the role Security Manager, or Security Engineer depending on their preferences and needs. The term Security Engineer can be used to emphasize the necessary technical skills.

One person may take the Security Manager (Security Engineer) role for multiple IT Systems or Bosch Products if the person has proven expertise, capacity, and if no conflict of interest arises.

4.2.4.1 Rights and Responsibilities

The Security Manager:

- (1) Supports the IT Owner or Product Responsible Office in the implementation of the cybersecurity requirements in section 4.3 and Attachment 1,
- (2) Supports the creation and maintenance of the cybersecurity relevant documentation,
- (3) Acts as the first point of contact regarding cybersecurity within the team developing or operating the IT System or Bosch Product,
- (4) Distributes information regarding the content of this C-Directive within the team developing or operating the IT System or Bosch Product,
- (5) Supports decisions on how to proceed with cybersecurity-relevant changes, vulnerabilities, and cybersecurity incident response,
- (6) Has the right to report concerns directly to the OE's CSO.



	C-Directive 09000	Issue/Amendment 1	Page 17/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

4.2.4.2 Required Competences

The following table provides guidance for the competence profile of a Security Manager (Security Engineer) based on the [Bosch competence model](#). The competence levels (1=Awareness to 5=Champion) are defined in the [Professional Development Journey \(PDJ\)](#). By the time of writing this C-Directive, trainings are being defined to support the OEs to cover a sub-set of these competences.

Competence	Competence level (1-5)
Secure software development	Domain specific: - minimum 1 competence with level 3 (Advanced) 2 additional competences with level 2 (Basic)
Security testing	
Communication and network security	
Cloud security	
Web security and application security	
Cryptography	
Identity and access management	
Security architectures and engineering	
Security of connected products	
Hardware security	
Embedded security	
Incident response	2
Risk management	2
Vulnerability management	2
Cybersecurity relevant laws, regulations, and standards	2
Product liability	2
Knowledge of the target domain	2
Knowledge of the OE's operational procedures along the Product or IT System life cycle.	2
Communication and moderation skills	2
Cooperation and networking skills	2
Trainings and coaching skills	2

2026-05-20 - SOCOS



	C-Directive 09000	Issue/Amendment 1	Page 18/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

4.2.5 Local Cybersecurity Contact (Local CSC) (DI)

- (1) The Local CSC executes cybersecurity tasks (see section 4.2.5.1) which require physical presence in the location. For these tasks, the Local CSC is the contact person for all IT Systems operated in the respective location.
- (2) For every Bosch location, a Local CSC must be nominated:
 - For Bosch locations where the BD field service is available, the Local CSC must be nominated by the local BD field service.
 - For Bosch locations where the BD field service is not available:
 - The OE management must nominate a Local CSC.
 - If multiple OEs are in the same location, the management of the location must nominate a Local CSC.

The list of Bosch locations is maintained by C/SB. See [Group Master Data / -object Location code](#).

The role Local CSC is not required for Bosch Products.

The role Local CSC is formerly known as Virus Protection Responsible (VPR).

4.2.5.1 Rights and Responsibilities

The implementation of the cybersecurity requirements in section 4.3 and Attachment 1 for individual IT Systems in a particular Bosch location is in the responsibility of the respective IT Owner.

The Local CSC:

- (1) Acts as a point of contact for C/CY in the location,
- (2) Must coordinate the cybersecurity activities with other roles in the same location, e.g., Local OT (see [CD 04602](#)),
- (3) Must support C/CY, particularly Bosch CERT, in case of a cybersecurity incident in the location,
- (4) Has the right to execute instructions given by Bosch CERT (see Attachment 2) in case of a cybersecurity incident, (e.g., disconnecting devices from the Bosch network),
- (5) Has the right to physically access the respective areas, e.g., IT rooms operated by the OE,
- (6) Must support C/CY, particularly the C/CY endpoint protection service (see Attachment 2), by ensuring the implementation of an accurate endpoint protection on the IT Systems in the location.



	C-Directive 09000	Issue/Amendment 1	Page 19/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

4.2.5.2 Required Competences

The following table provides guidance for the competence profile of a Local Cybersecurity Contact (Local CSC) based on the [Bosch competence model](#). The competence levels (1=Awareness to 5=Champion) are defined in the [Professional Development Journey \(PDJ\)](#).

Competence	Competence level (1-5)
Communication and network security	2
Incident response	2
Endpoint protection	2

4.3 Cybersecurity Life Cycle (ND)

- (1) The Cybersecurity Life Cycle (CSL) defines required cybersecurity-related activities along the life cycle of an IT System or Bosch Product. As such, the CSL complements the generic life cycle of a system and extends it with cybersecurity-relevant activities.
- (2) The activities are grouped according to life cycle phases as depicted in Figure 3. Please note:
 - While all CSL activities are mandatory, the depicted sequence is not. The Figure shows a typical sequence that fits in many cases, but not necessarily all.
 - The figure groups an activity in a phase, where the main effort is typically carried out. It may well begin before this phase and continue beyond it, though.

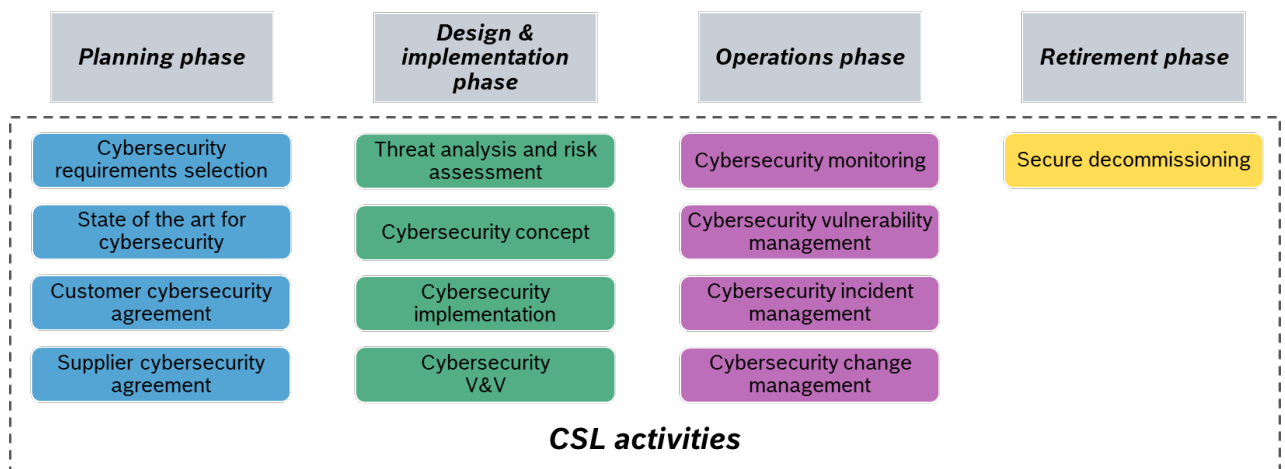


Figure 3: CSL activities mapped to typical life cycle phases.

For additional information and practical guidance, please refer to [the CSL handbook](#).



	C-Directive 09000	Issue/Amendment 1	Page 20/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

- (3) CSL implementation is mandatory for all Bosch Products and for new IT Systems with very high protection requirements (introduced after this CD has become effective) also if intended for internal use. For all other IT Systems with very high protection requirements the CSL implementation will become mandatory from January 1st, 2028. The use of the term “IT Systems and/or Bosch Products” in the remaining paragraphs of this section refers to this scope.

The CSL will be extended in future releases of this C-Directive to eventually cover all IT Systems and Bosch Products.

It is recommended to apply the CSL for all IT Systems (beyond those for which its application is mandatory) already now.

- (4) Product developments which have started before this C-Directive has become effective may continue to apply the SEP according to CD 07000 or to previous applicable versions of the Bosch Norm series N103 including applicable transition periods stated therein.
- (5) The IT Owner or the Product Responsible Office, respectively, is responsible for the execution of all CSL activities (see section 4.2.3). Artefacts and results from the activities must be documented in an appropriate way, making them traceable and auditable. The OE CSO must ensure that criteria for appropriateness are in place (e.g., by creating ‘definitions of done’ for all activities).

The scope of each CSL activity and the required effort may vary to a large degree, depending on the characteristics of the IT System or Bosch Product.

As an example, a large in-house development project will typically spend more time and capacity in the design phase than a project tasked with the deployment and configuration of externally acquired standard software.

- (6) CSL activities must also consider external conditions that directly affect the cybersecurity of the IT System or Bosch Product.
- (7) For digital touchpoints within the framework of external social media platforms, the OE may decide that the CSL is not applied if there are no relevant risks associated.

External conditions include, for instance, the supply chain or manufacturing processes (in case of tangible systems or Bosch Products).

4.3.1 Planning Phase

- (1) The planning phase of the CSL captures and documents cybersecurity requirements for the corresponding IT System or Bosch Product. Cybersecurity requirements can originate from different domains, in particular customer demands, Bosch corporate directives (e.g., regarding safety or data protection requirements that imply cybersecurity controls), and regulatory



	C-Directive 09000	Issue/Amendment 1	Page 21/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

constraints represented by the applicable state of the art (see corresponding sections below). Furthermore, adequate requirements and obligations towards suppliers must be derived.

- (2) Cybersecurity requirements must be managed and documented throughout the lifetime of the IT System or Bosch Product.

4.3.1.1 Cybersecurity Requirements Selection

- (1) Security requirements from relevant stakeholders must be identified and documented including their origin.
- (2) Additionally, the mandatory cybersecurity requirements and controls of Attachment 1 must be identified and implemented based on the type of system.
- (3) The IT Owner or the Product Responsible Office, respectively, is responsible that all applicable requirements are included.

Typical examples include:

- [CD 0302 “Requirements for Development of Software and Software-Intensive Systems”](#)
- [CDQ 0214 “Requirements on Product Safety”](#)
- [CD 02900 “Information Security and Data Protection”](#)

4.3.1.2 State of the art for Cybersecurity

- (1) The state of the art for cybersecurity must be determined for each IT System and Bosch Product (or product category, where applicable). The state of the art requires measures to avoid known or reasonably foreseeable risks based upon generally available, not necessarily new, technical knowledge and recognized solutions. The state of the art includes:
 - statutory, regulatory, and normative requirements,
 - cybersecurity concepts according to standard industry practice, and
 - applicable methods, testing technology, and manufacturing processes.
- (2) A Bosch Product must be at least equal to, or above the state of the art for cybersecurity at that point in time when it is placed on the market. For IT Systems the state of the art must be considered to determine adequate security measures.
- (3) The state of the art for cybersecurity for Bosch Products must be identified latest upon defining the requirements.
- (4) For Bosch Products the determination must be continuously updated and reviewed at least yearly until the end of delivery.



	C-Directive 09000	Issue/Amendment 1	Page 22/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

The main definition of the term “State of the art” can be found in [RBGF 182](#).

The questionnaire in Annex 2 of [CGP 00214-200](#) is applicable for the determination of the state of the art and should be applied to cybersecurity.

For Bosch Products the term ‘placed on the market’ refers to the point in time when the individual unit of the product is made available on the market for the first time. The product is made available when it is supplied for distribution, consumption or use on the market in the course of a commercial activity, whether in return for payment or free of charge.

The [Bosch EISA](#) can serve as a starting point to the determined state of the art.

4.3.1.3 Customer Cybersecurity Agreement

- (1) If an IT System or Bosch Product is developed or adapted according to specific customer requirements, the customer’s cybersecurity requirements together with suited verification and validation criteria must be identified and documented in a customer cybersecurity agreement.
- (2) This must be done before the start of the development or adaption of the IT System or Bosch Product, and continuously updated when necessary.
- (3) As part of the customer cybersecurity agreement, the responsibilities between the customer and Bosch must be clarified and documented.
- (4) In addition, the customer’s input for the cybersecurity concept must be clarified and documented.

An OE may provide dedicated templates for creating customer cybersecurity agreements.

4.3.1.4 Supplier Cybersecurity Agreements

- (1) The goal of supplier cybersecurity agreements is to manage and to document cybersecurity risks induced by supplied components.
- (2) Adequate agreements must be created for applicable suppliers (either external or internal) which contribute all sorts of goods (incl. trade goods, software, parts, components) or services (e.g., computing infrastructure and platforms) with cybersecurity relevance.
- (3) By means of supplier agreements, it must be ensured and documented that:
 - Supplied components do not endanger the respective IT System or Bosch Product. This is achieved by defining suited requirements for the supplied components and organizational requirements for the supplier, e.g., for vulnerability management,
 - Cybersecurity responsibilities are contractually agreed with the supplier, including those for vulnerability and cybersecurity incident management,
 - The supplier provides all applicable cybersecurity-relevant information regarding the supplied parts, such as inventory lists for software and hardware of every variant and version of the IT System or Bosch Product, certifications, list of known defects etc.



	C-Directive 09000	Issue/Amendment 1	Page 23/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

- A purpose-fitting cybersecurity assurance of the delivered component is ensured, e.g., by employing suitable verification and validation methods, audits, and assessments.
- (4) In case of supplied standard components (components off the shelf, COTS) there are usually no individual arrangements on cybersecurity requirements or responsibilities. It must nonetheless be checked and documented whether the supplied components are suitable and meet the defined requirements.

For certain use cases, the central purchasing organization contractually agrees standardized cybersecurity requirements with suppliers. It is the responsibility of the IT Owner or Product Responsible Office, respectively, to assess whether these are sufficient, and to follow-up on supplier inquiries regarding the cybersecurity-related content of these requirements. The IT Owner or Product Responsible Office may consult with the OE CSO regarding such inquiries.

Examples for such standardized cybersecurity requirements include:

- Information in [Docupedia](#) for new suppliers of software and cloud services
- Bosch Cybersecurity General Requirements (see [CGP 80010-400](#)) for automotive suppliers
- General delivery instructions for machines, installations, and production equipment (see [N51M M27](#))

4.3.2 Design and Implementation Phase

- (1) This phase comprises all necessary development steps to derive the adequate cybersecurity requirements and controls for the individual IT System or Bosch Product and to integrate them in a reliable way. The design and implementation phase also covers manufacturing (in case of tangible systems) and deployment of an IT System or Bosch Product.
- (2) Adequacy of requirements and controls depends, e.g., on the IT System's or the Bosch Product's deployment context, its threat exposure, and the regulatory context in target markets.
- (3) Cybersecurity design and implementation must be aligned with the generic development process and integrated from the very beginning ("by design").
- (4) In case of Bosch Products, the design and implementation phase must be finished at the latest when QG4, SW-QG4 or the Market Introduction Gate (MIG) (see [CDQ 00304](#)) is reached.

4.3.2.1 Threat Analysis and Risk Assessment

- (1) The threat analysis and risk assessment (TARA) must systematically identify, assess, and prioritize cybersecurity risks with appropriate techniques for a documented scope.
- (2) The scope of the TARA must reflect the intended operational environment.
- (3) Threats and risks must be analyzed for each specific IT System or Bosch Product throughout the life cycle.



	C-Directive 09000	Issue/Amendment 1	Page 24/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

- (4) If an IT System or Bosch Product is derived from a platform or another IT System or Bosch Product, cybersecurity requirements and controls that are already implemented must be reflected in the threat analysis and risk assessment.
- (5) The TARA must consider the requirements identified in section 4.3.1.
- (6) The TARA must reflect the initial concept of the system and boundary conditions such as the business context, legal requirements (for each applicable area of jurisdiction, usually a country), and applicable industry standards.
- (7) As a result, the TARA describes all threats with their resulting risks and identifies cybersecurity requirements/controls, which are feasible to reduce identified risks to an acceptable level.
- (8) Residual risks (i.e. remaining risks after a possible mitigation) must be documented and approved according to section 4.2.3.1.

4.3.2.2 Cybersecurity Concept

- (1) The cybersecurity concept must derive appropriate cybersecurity requirements and cybersecurity controls (regarding the previously identified risks) for the IT System or Bosch Product and their environment.
- (2) In doing so, it must address the outcome of the threat analysis and risk assessment and must make explicit, which risks are covered.
- (3) The cybersecurity concept delivers the details for the implementation of cybersecurity measures and must cover the entire life cycle of the IT System or Bosch Product up to and including its eventual decommissioning.

As the cybersecurity concept covers the entire life cycle, it must also reflect activities that take place at a later stage of the life cycle, such as cybersecurity monitoring or the secure decommissioning of the Bosch Product or IT System. This may also include manufacturing aspects (for tangible products or systems).

- (4) All cybersecurity requirements must be managed subsequently throughout the complete CSL.

Special attention must be paid to cybersecurity requirements that also have an impact on safety-related risks or risks related to data protection.

- (5) The concept must consider the environment of the IT System or Bosch Product during development, manufacturing, and operation and the intended support period of the IT System or Bosch Product.
- (6) Residual risks and unresolved cybersecurity requirements (and optionally the cybersecurity concept itself) must be approved according to section 4.2.3.1. The OE CSO must be informed about these. It must be checked whether instruction obligations (e.g., towards the customer) arise from residual risks. It must further be checked if a customer needs to approve the residual risks, e.g., in cases where validation criteria from section 4.3.1.3 cannot be met.



	C-Directive 09000	Issue/Amendment 1	Page 25/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

- (7) To ensure that no Bosch Products are placed on the market with not adequately mitigated safety risks (which might be induced by not-mitigated cybersecurity risks), the OE QM (or a corresponding safety-related role on project level) must be involved before approval by the project sponsor (in case of Bosch Products).

4.3.2.3 Cybersecurity Implementation

- (1) To ensure the secure implementation of the IT System or Bosch Product, a cybersecurity implementation concept must be defined and applied, which contains adequate measures to reduce the likelihood for the occurrence of vulnerabilities on the implementation level. It describes, on the implementation level, how to avoid known cybersecurity problems and defines best practices related to specific technologies used, e.g., programming guidelines.
- (2) The cybersecurity implementation concept also covers the configuration or adaption of acquired IT Systems or products, including standard software.

4.3.2.4 Cybersecurity Verification and Validation

- (1) For each IT System or Bosch Product appropriate verification and validation (V&V) methodologies must be selected and applied to provide sufficient confidence that it meets the defined and implemented cybersecurity requirements and does not induce unacceptable cybersecurity risks.
- (2) In addition, the mandatory testing requirements from Attachment 1 apply. Cybersecurity V&V measures must be documented in a cybersecurity V&V concept.

Common methods for cybersecurity V&V are listed in CGP 09000-005 (Security V&V Guideline), which is recommended to be used for the selection of appropriate cybersecurity testing methods.

ISO/IEC/IEEE 29119-1 defines the terms verification and validation (and the delineation to 'testing') along with a classification of corresponding activities.

4.3.3 Operations Phase

- (1) The operations phase comprises cybersecurity-related activities that must be conducted while the IT System or Bosch Product is operated. The prerequisites to successfully carry out these activities must be ensured in advance, i.e., *before* the IT System or Bosch Product enters operation.

4.3.3.1 Cybersecurity Monitoring

- (1) All IT Systems and Bosch Products must be monitored for cybersecurity weaknesses, vulnerabilities, cybersecurity incidents, and changes of the operational context (such as regulatory implications) over their entire life cycle.



	C-Directive 09000	Issue/Amendment 1	Page 26/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

- (2) Relevant information from field monitoring and operations must also be considered as input for the security monitoring process if applicable. Monitoring obligations extend to related systems (e.g., infrastructure services, third-party services) insofar as they may affect the cybersecurity of the IT System or Bosch Product.
- (3) The responsibility for cybersecurity monitoring is with the IT Owner or the Product Responsible Office, respectively. The IT Owner or the Product Responsible Office must establish appropriate interfaces to C/CY (see Attachment 2) for alignment of centrally steered and OE-wide cybersecurity monitoring activities.

The Bosch CERT is an appropriate contact in this regard (see Attachment 2 for more information).

4.3.3.2 Cybersecurity Vulnerability Management

- (1) The IT Owner or the Product Responsible Office, respectively, must ensure that clear responsibilities and communication paths for cybersecurity vulnerability management are in place before an IT System or Bosch Product is released.
- (2) The IT Owner or the Product Responsible Office, respectively, must ensure that vulnerabilities in their IT System or Bosch Products are identified, classified, prioritized, remediated, and mitigated or accepted in due time according to the IT System's or the Bosch Product's cybersecurity concept and in alignment with requirements defined in Attachment 1.
- (3) To leverage synergies and to prevent inefficiencies, it must be ensured that cybersecurity vulnerability management activities for a specific IT System or Bosch Product are aligned with corresponding measures by the OE CSO (see section 4.2.2.1.4) and by C/CY (see Attachment 2).

4.3.3.3 Cybersecurity Incident Management

- (1) The IT Owner or the Product Responsible Office, respectively, must ensure that clear responsibilities and communication paths for cybersecurity incident management are in place before an IT System or Bosch Product is released. Corresponding results must be documented and followed in case of actual cybersecurity incidents affecting the IT System or Bosch Product.
- (2) The implemented measures for cybersecurity incident management must take into account the IT System's or the Bosch Product's specific conditions, as well as Bosch-wide requirements for cybersecurity incident management defined in Attachment 1.

4.3.3.4 Cybersecurity Change Management

- (1) Modifications of an IT System or Bosch Product or its deployment environment must be analyzed regarding its cybersecurity related impacts.
- (2) A security change is any change that may affect the cybersecurity of the IT System or Bosch Product (both for better or worse) in a significant way, e.g., by modifications of the system



	C-Directive 09000	Issue/Amendment 1	Page 27/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

architecture, changes of the legal context (including the state of the art) or the threat landscape. In this case, the modification must be treated as a security change and affected documentation in regard of the CSL must be updated and approved according to the activities in this document. Security patches to close identified vulnerabilities are not seen as a significant change in the context of this section.

Regarding change management for Bosch Products, also refer to [CDQ 0404](#).

4.3.4 Retirement Phase

- (1) The retirement phase comprises cybersecurity-related activities that must be conducted at the end of an IT System's or Bosch Product's life cycle.

4.3.4.1 Secure Decommissioning

- (1) The intention of secure decommissioning is to ensure that an IT System or Bosch Product cannot induce unacceptable risks after the end of its intended operational period. Typical risks include the misuse or disclosure of data or cryptographic material stored in the IT System or Bosch Product.
- (2) Where applicable, adequate instructions for properly executing decommissioning controls must be provided and must be made available to the IT Owner of the IT System or the entity operating the Bosch Product (e.g., the customer/consumer).
- (3) If the IT System or Bosch Product is operated by or on behalf of Bosch, the corresponding IT Owner or Product Responsible Office must ensure that applicable decommissioning procedures are executed in the intended way.

While decommissioning takes place at the end of the life cycle, corresponding prerequisites, controls and documentation (e.g., user instructions) must usually be considered and derived during the planning phase, design and implementation phase.

4.4 PDCA Cycle (ND)

- (1) The PDCA cycle must enable C/CYG to validate the effectiveness and appropriateness of this C-Directive following the requirements of [RBGF 103](#). It creates a feedback cycle for the applicability of the C-Directive within the organization.
- (2) **Plan:** The requirements of this C-Directive are developed by C/CYG. They are based on international standards, the current threat situation, legal requirements, the organization setup, feedback from Bosch organizational units (see section 4.1), and the collaboration with expert networks.
- (3) **Do:** In this phase the OEs must implement the requirements as defined in this C-Directive and its attachments.



	C-Directive 09000	Issue/Amendment 1	Page 28/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

(4) **Check:** In this phase the implementation and effectiveness of the requirements as defined in this C-Directive are validated by C/CYG to assess its impact on the current risk situation. The intention of these checks is to identify improvement potential with respect to the C-Directive itself. The following validation mechanisms are used by C/CYG:

- Spot checks following suited assessment schemes
- Self-Assessments
- Regular management reporting
- Statistics of quality gate assessments

(5) **Act:** Corrections and adaptations based on the findings of the "Check" phase are performed by C/CYG and the C-Directive is adapted accordingly.

4.5 Update of Attachments (ND)

(1) Modifications of attachments of this C-Directive, which do not change the basic content, follow an independent release process (see [RBGF 103](#) and section 4.2.3). The modifications of the attachments are released by C/CY following the four-eyes principle and are documented by C/CY.

4.6 Deviation Requests (ND)

(1) Deviation requests for regulations of this C-Directive marked as DI will be handled by C/CY following an aligned and risk-oriented approval process.

The process and the corresponding WorkOn are described in CGP 09000-004 "Deviation Request Documentation".

Release

G7

Signed Rückert



	C-Directive 09000	Issue/Amendment 1	Page 29/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

Attachments

- [ATT-001] CD 09000-001 Cybersecurity Requirements Catalogue
- [ATT-002] CD 09000-002 Corporate Department for Cybersecurity
- [ATT-003] CD 09000-003 RBGF 177-001 System Mapping

Corporate Good Practice Documents

- [CGP 09000-001] CGP 09000-001 Cybersecurity Lifecycle Handbook
- [CGP 09000-002] CGP 09000-002 Bosch EISA
- [CGP 09000-003] CGP 09000-003 Cybersecurity Incident Response Plan
- [CGP 09000-004] CGP 09000-004 Deviation Requests
- [CGP 09000-005] CGP 09000-005 Security V&V Strategy Guideline
- [CGP 09000-006] CGP 09000-006 Business Critical Assets
- [CGP 09000-007] CGP 09000-007 M&A Activities and CD 09000 compliance
- [CGP 09000-100] CGP 09000-100 Network Integration of Bosch Sites

Overview of referenced Corporate regulations

Regulation	Entire regulation or single document	SOCOS file name	Creating corporate department
RBGF 100	Entire Regulation	RBGF-00100	C/LS
RBGF 103	Entire Regulation	RBGF-00103	C/SB
RBGF 104	Entire Regulation	RBGF-00104	C/CO
RBGF 105	Entire Regulation	RBGF-00105	C/CM
RBGF 177	Entire Regulation	RBGF-00177	C/ID
RBGF 182	Entire Regulation	RBGF-00182	C/QM
CDQ 00214	Entire Regulation	CD-00214	C/QM
CDQ 00302	Entire Regulation	CD-00302	C/QM



	C-Directive 09000	Issue/Amendment 1	Page 30/30
Responsible G7	Cybersecurity	Author C/CY	Date Jan. 1, 2025

CDQ 00304	Entire Regulation	CD-00304	C/QM
CD 02500	Entire Regulation	CD-02500	M/SX
CD 02900	Entire Regulation	CD-02900	C/CM
CD 04602	Entire Regulation	CD-04602	C/TM
CD 05106	Entire Regulation	CD-05106	C/ID
CD 07061	Entire Regulation	CD-07061	C/ID
CD 80008	Entire Regulation	CD-80008	C/SC

Revision History

Issue	Date	Editor	Description of amendment
1	2025-01-01	C/CYG	Initial version
1	2025-04-14	C/CYG	Correction of spelling, Correcting Reference to Product Responsible Office

2026-05-20 - SOCOS

